

Web Aplikazio Hobekuntza

Larrain Gonzalez
Gaizka Divasson
Surya Ortega
Asier Barrio
Erlantz Lorz

Ahulezien Informea.....	3
Arrisku Handiko Ahuleziak.....	3
Arrisku Ertaineko Ahuleziak.....	5
Arrisku Baxuko Ahuleziak.....	8

Ahulezien Informea

Arrisku Handiko Ahuleziak

Zenbakia	1
Detektatutako ahulezia	Mysql/Sql injekzioa
Deskribapena	Konpondutako arazoaren artean hurrengoak egon dira. - Login: saioa hasi zitekeen kredentzial zuzenik gabe. - Add_item, modify_item eta modify_user: atributu hutsak agertu zitezkeen. - Show_item eta modify_item: query string-aren bidezko injekzioa item desberdinak aldatzeko edo ikusteko. - Delete: item guztiak eragiketa bakarrarekin borratzeko aukera.
Konponketa	2 konponketa desberdin aplikatu ditugu, bata kontsultak egiterakoan, bestea query string-eko datuak hartzerakoan. Hurrengo artxiboak aldatu dira: ➤ login/index.php ➤ modify_item/index.php ➤ delete_item/index.php ➤ show_item/index.php ➤ register/index.php ➤ add_item/index.php ➤ modify_user/index.php Kodearen aldaketaren adibidea, aldagaiak parametrizatuta eta prepare statement-ak erabili: Lehen (register): <pre>\$sql = "INSERT INTO erabiltzaileak (Erabiltzaile, Izen_Abizen, NAN, Telefonoa, Jaio_Data, Email, Pasahitza) VALUES ('\$user', '\$iz_abz', '\$nan', \$tlnf, '\$jaiodata', '\$mail', '\$pas')";</pre> Orain (register): <pre>\$stmt = \$conn->prepare("INSERT INTO erabiltzaileak (Erabiltzaile, Izen_Abizen, NAN, Telefonoa, Jaio_Data, Email, Pasahitza) VALUES (?, ?, ?, ?, ?, ?, ?)"); if (\$stmt) { \$stmt->bind_param("sssssss", \$user, \$iz_abz, \$nan, \$tlnf, \$jaiodata, \$mail, \$pas_hash);</pre>

	Bestalde, query string bidezko injekzioa ekiditzeko adibidea: Lehen (modify_item): <pre>if (isset(\$_GET['id'])) { \$id = \$_GET['id']; }</pre> Orain (modify_item): <pre>if (isset(\$_GET['id'])) { \$id_raw = \$_GET['id']; if (filter_var(\$id_raw, FILTER_VALIDATE_INT) === false) { http_response_code(400); die('id-a ez da bailozkoa'); } \$id = (int)\$id_raw; } else { \$id = null; }</pre>
Commit-ak	➤ https://github.com/lagonzal42/segurProiektu/commit/62aa9e17ca0064a07a44a77d12060fab541bcde6 ➤ https://github.com/lagonzal42/segurProiektu/commit/c0a56c677c20bfe75dfdbf1896621c3808879ebc ➤ https://github.com/lagonzal42/segurProiektu/commit/7bc5b56ae264147f5a99e476381d5403bbc40915



Arrisku Ertaineko Ahuleziak

Zenbakia	2
Detektatutako ahulezia	CSFR aurkako token falta
Deskribapena	CSFR token falta izatea eragin zezakeen erasotzaileak erabiltzaile baten izenean ekintzak egitea. Horretarako erasotzaileak esteka arrunt bat sortu zezakeen eta erabiltzaileak klik egitekotan, erasotzaileak kontrola hartuko zukeen. Token-a jartzeak saihestu egingo du erasotzaileak erabiltzailearen saioaren kontrola izatea, token bakoitza saio bakoitzeko bakarra baita.
Konponketa	Kodean hurrengoa sartu dugu behar izan duten php artxiboeta. Aldatutako artxiboak: > add_items/index.php > register/index.php > login/index.php > modify_item/index.php <pre>if (empty(\$_SESSION['csrf_token']) empty(\$_SESSION['csrf_time']) (\$_SESSION['csrf_time'] + 3600) < time()) { \$_SESSION['csrf_token'] = bin2hex(random_bytes(32)); \$_SESSION['csrf_time'] = time(); } if (\$_SERVER["REQUEST_METHOD"] === "POST") { \$posted_token = \$_POST['csrf_token'] ?? ''; if (empty(\$posted_token) !hash_equals(\$_SESSION['csrf_token'], \$posted_token)) { http_response_code(403); echo "<p style='color:red;'>CSRF token falta da edo ez da egokia.</p>"; exit(); } \$_SESSION['csrf_token'] = bin2hex(random_bytes(32)); \$_SESSION['csrf_time'] = time(); }</pre>

	<pre>HTML zatian hurrengoak jarri behar izan da:</pre> <pre><input type="hidden" name="csrf_token" value="<?php echo htmlspecialchars(\$_SESSION['csrf_token'] ?? '', ENT_QUOTES); ?>"></pre>
Commit-ak	➤ https://github.com/lagonzal42/segurProiektu/commit/5224325574e296958f8a31e2e8776c6cb7f65e86

Zenbakia	3
Detektatutako ahulezia	Content Security Policy (CSP) goiburua ez konfiguratuta.
Deskribapena	Goiburua jarri aurretik erasotzaile batek script kaltegarri bat bidal zitekeen eta nabigatzaileak exekutatu zuen, jatorria begiratu gabe. Exekuzio honek cookie lapurketak, saioak bahitzea edo nabigatzailearen informazio filtraketa ekar zitekeen. Goiburu hau konfiguratuz, ekiditzen da kanpoko script-ak irekitzea, bakarrik web sistemak ezagutzen dituenak irekiz.
Konponketa	Arazoa konpontzeko hurrengoak sartu dugu beharrezkoak izan diren fitxategietan: <pre>\$csp_nonce = base64_encode(random_bytes(16));</pre> <pre>header("Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'self' 'nonce-\$csp_nonce'; img-src 'self' data:; object-src 'none'; base-uri 'self'; frame-ancestors 'none'; form-action 'self';");</pre> CSS mantentzeko eta arazorik ez ekartzeko, HTML kode barruan dagoen <style>-ean hurrengoak jarri da: <pre><style nonce="<?= htmlspecialchars(\$csp_nonce, ENT_QUOTES) ?>"></pre>

	Aldatutako fitxategiak: ➤ index.php ➤ add_items/index.php ➤ delete_item/index.php ➤ register/index.php ➤ login/index.php ➤ items/index.php ➤ modify_item/index.php ➤ show_item/index.php
Commit-ak	➤ https://github.com/lagonzal42/segurProiektu/commit/ee11cbe25de16831dcbc20238ac920e0a39a906c

Zenbakia	4
Detektatutako ahulezia	Clickjacking aurkako goiburu falta
Deskribapena	Goiburu hau izan baino lehen, web sistema beste webgune baten iframe batean agertu zitekeen, erabiltzaileari engainatuz klik faltsuen bidez. Modu honetan erabiltzailearen izenean operazio arriskutsuak egin zitezkeen, hala nola, zeozer erostea, saioa ixtea edo erabiltzailea administratzailea izanez gero azken honen ekintzak burutzea.
Konponketa	Konpontzeko php artxibo guztietan hurrengoa idatzi da, orrialde hasieran edo session_start ostean: <pre>header("X-Frame-Options: DENY");</pre> Eraldatutako artxiboak: ➤ index.php ➤ add_items/index.php ➤ delete_item/index.php ➤ register/index.php ➤ login/index.php ➤ items/index.php ➤ modify_item/index.php ➤ show_item/index.php
Commit-ak	➤ https://github.com/lagonzal42/segurProiektu/commit/f616aa390310b2b354f39f7bf6534cc05552c59b ➤ https://github.com/lagonzal42/segurProiektu/commit/c171f416217f9382bbe0ad166df80191b855af5



Arrisku Baxuko Ahuleziak

Hurrengo kasuetan cookie-ekin agertzen ziren arazoak era errazagoan tratatzeko php 7.2.2 bertsiotik 7.3-ra eguneratu dugu gure Dockerfile-ean. Era horretan “*session_set_cookie_params*” erabili ahal izateko.

Zenbakia	5
Detektatutako ahulezia	HttpOnly flag gabeko Cookie-a
Deskribapena	Cookie batek ez daukanean HTTPOnly flagik javascripteko kodetik atzigarria. Gure kasuan javascript bidez cookie-a atzitzeak sesioaren lapurketa gauzatu lezake. Beraz, Cookie-ari HTTPOnly flag-a emanaz lortzen duguna da bere informazioa XSS atakeen aurka babestea.
Konponketa	Aldatutako fitxategiak: ➤ index.php ➤ add_items/index.php ➤ delete_item/index.php ➤ register/index.php ➤ login/index.php ➤ items/index.php ➤ modify_item/index.php ➤ show_item/index.php <u>Lehen:</u> <pre><?php session_start(); ?> <!DOCTYPE html></pre> <u>Orain:</u> <pre><?php session_set_cookie_params(['lifetime' => 0, 'path' => '/', 'secure' => false, 'httponly' => true, 'samesite' => 'Strict',]); session_start(); ?> <!DOCTYPE html></pre>

Commit-ak	➤ https://github.com/lagonzal42/segurProiektu/commit/7274cbc23bfa7e4bc30495408afab971ae787f20 ➤ https://github.com/lagonzal42/segurProiektu/commit/7e75d262ec3bcaffc7d4ab654ba38557adf0a80 ➤ https://github.com/lagonzal42/segurProiektu/commit/297b4b15a29563eae44711bc6c6e91ff409cda76
-----------	---

Zenbakia	6
Detektatutako ahulezia	Same site flag gabeko Cookie-a
Deskribapena	Same site gabeko cookie bat erabiltzen badu webgune batek, beste webgune batetik egiten diren eskaeretan erabili daiteke, hau da, gurea ez den web gune batetik eskaerak egin ditzakete gure erabiltzaileen sesio cookie-a erabiliz eta horren bidez bere datu pertsonalak lapurtu edo aldatu.
Konponketa	Aldatutako fitxategiak: ➤ index.php ➤ add_items/index.php ➤ delete_item/index.php ➤ register/index.php ➤ login/index.php ➤ items/index.php ➤ modify_item/index.php ➤ show_item/index.php <u>Lehen:</u> <pre><?php session_start(); ?> <!DOCTYPE html></pre> <u>Orain:</u> <pre><?php session_set_cookie_params(['lifetime' => 0, 'path' => '/', 'secure' => false, 'httponly' => true, 'samesite' => 'Strict',]); session_start(); ?> <!DOCTYPE html></pre>

Commit-ak (HTTPonly-ren berdinak)	➤ https://github.com/lagonzal42/segurProiektu/commit/7274cbc23bfa7e4bc30495408afab971ae787f20 ➤ https://github.com/lagonzal42/segurProiektu/commit/7e75d262ec3bcfffc7d4ab654ba38557adf0a80 ➤ https://github.com/lagonzal42/segurProiektu/commit/297b4b15a29563eae44711bc6c6e91ff409cda76
---	---

Zenbakia	7
Detektatutako ahulezia	Depurazio errore mezua
Deskribapena	Arazo honek gehiegizko informazioa erakusten du, hala nola, fitxategien path osoak, SQL errore mezuak edo PHP izandako “fatal errors”. Aipatutakoa erasotzaile batek erabili ditzake web sisteman sartzeko, SQL kontsulta egitura jakin dezake, web sistemaren antolakuntza eta egitura jakin dezake, besteak beste.
Konponketa	Arazo honetan .htaccess fitxategia eraldatu dugu, honetan ekidituko dugu web sistematik kanpo dauden fitxategiak irekitzea. Horretarako hurrengoa idatzi dugu: <pre> <IfModule mod_rewrite.c> RewriteEngine On RewriteCond %{REQUEST_URI} ^/(robots\.txt sitemap\.xml readme\.txt phpinfo\.php composer\.json lock) package\.json yarn\.lock webpack\.config\.js server-status config \.php \.env \.git \.svn backup bak zip tar gz) [NC] RewriteRule ^ - [R=204,L] RewriteCond %{REQUEST_FILENAME} !-f RewriteCond %{REQUEST_FILENAME} !-d RewriteRule ^([^\/]*)\$ \$1.php [L] </IfModule> </pre>
Commit-ak	➤ https://github.com/lagonzal42/segurProiektu/commit/ee11cbe25de16831dcbc20238ac920e0a39a906c

Zenbakia	8
Detektatutako ahulezia	Aplikazio dibulgazio errorea
Deskribapena	Arazo honek aplikazioari buruzko informazioa erakusten zuen, hala nola, zerbitzariaren bertsioa edo erabilitako programazio lengoaia. Datu hauek erakutsiz, erasotzailea erabili zitzakeen jakiteko sistemak izango zituen ahultasunak eta horietatik abiatuta webgunera sartu eta nahi zuena egin, adibidez datuen lapurketa.
Konponketa	Arazo hau konpontzeko, behar izan diren php artxibo guztietan hurrengoa idatzi dugu: <pre>header_remove("X-Powered-By"); header("Server: SegurServer");</pre> Eraldatutako artxiboak: ➤ index.php ➤ add_items/index.php ➤ delete_item/index.php ➤ register/index.php ➤ login/index.php ➤ items/index.php ➤ modify_item/index.php ➤ show_item/index.php
Commit-ak	➤ https://github.com/lagonzal42/segurProiektu/commit/ee11cbe25de16831dcbc20238ac920e0a39a906c

Zenbakia	9
Detektatutako ahulezia	Zerbitzaria informazioa bidaltzen du HTTP erantzun goiburuaren "X-Powered-By" zatia erabilita.
Deskribapena	Goiburua jarri aurretik erasotzaile batek jakin zezakeen sortutako web sistema erabilitako lengoaia eta teknologia. Datu hauek jakinda erasotzaileak jakin zitezakeen sistemak izango zituen ahultasun guztiak eta hori aprobeztatu nahi dituzten datuak hartzeko. "X-Powered-By" goiburua kenduz, aurretik aipatutakoa ekiditu dugu.
Konponketa	Konpontzeko php artxibo guztietan hurrengoa idatzi da, orrialde hasieran edo session_start ostean: <pre>header_remove("X-Powered-By");</pre> Eraldatutako artxiboak: ➤ index.php ➤ add_items/index.php ➤ delete_item/index.php ➤ register/index.php ➤ login/index.php ➤ items/index.php ➤ modify_item/index.php ➤ show_item/index.php
Commit-ak	➤ https://github.com/lagonzal42/segurProiektu/commit/f616aa390310b2b354f39f7bf6534cc05552c59b ➤ https://github.com/lagonzal42/segurProiektu/commit/c171f416217f9382bbee0ad166df80191b855af5

Zenbakia	10
Detektatutako ahulezia	Zerbitzarian bertsio informazioa filtratzen du HTTP erantzun goiburuaren "Server" zatia erabilia
Deskribapena	Goiburua jarri aurretik erasotzaile batek jakin zezakeen sistemak erabilitako bertsioa, web zerbitzaria, erabilitako sistema eragilea, beste datu gehiagoren artean. Datu guzti honekin erasotzaileak badaki sistemak izango dituen ahultasunak eta hori erabili zezakeen datuak lapurtzeko. HTTP-ren "Server" goiburuan informazio gehigarria kenduta, arazoa ekiditu dugu.
Konponketa	Arazo hau konpontzeko Docker-ean hurrengo zatia gehitu behar izan da: <pre>RUN echo "ServerTokens Prod\nServerSignature Off" >> /etc/apache2/conf-available/security.conf && \ a2enconf security</pre> <pre>RUN a2enmod headers && \ echo 'Header always set Server "SegurServer"' >> /etc/apache2/conf-enabled/security.conf</pre> Lehenengo zatiarekin ekiditzen dugu Apache-ren bertsioa erakustea eta errore bat ematekotan ez erakustea, bigarreanean mod_headers izeneko modulua aktibatzen da, header-ak Apachetik aldatzeko.
Commit-ak	➤ https://github.com/lagonzal42/segurProiektu/commit/e2ebf8b8f8b58c8185b30d13d9517f7ea3377959

Zenbakia	11
Detektatutako ahulezia	X-Content-Type-Options goiburua falta da.
Deskribapena	Goiburu hau eduki gabe, web sistemak asmatzen zuen fitxategiaren edukia, alegia, <i>irudi.jpg</i> izeneko artxibo bat JS edo HTML kaltegarria duena, beste JS edo HTML kodearen ordeztatik sistemak exekutatu zezakeen XSS edo saio-cookien lapurketa gauzatuz. "X-Content-Type-Options" goiburua jarrita, ekiditu dugu aurretik aipatu dena.
Konponketa	Konpontzeko php artxibo guztietan hurrengoak idatzi da, orrialde hasieran edo session_start ostean: <pre>header("X-Content-Type-Options: nosniff");</pre> Era berean .htaccess fitxategia modifikatu behar izan dugu, JavaScript-eko artxiboak errore bera ez edukitzeko: <pre><IfModule mod_headers.c> <FilesMatch "\.js\$"> Header set X-Content-Type-Options "nosniff" </FilesMatch> </IfModule></pre> Eraldatutako artxiboak: ➤ index.php ➤ add_items/index.php ➤ delete_item/index.php ➤ register/index.php ➤ login/index.php ➤ items/index.php ➤ modify_item/index.php ➤ show_item/index.php ➤ .htaccess
Commit-ak	➤ https://github.com/lagonzal42/segurProiektu/commit/f616aa390310b2b354f39f7bf6534cc05552c59b ➤ https://github.com/lagonzal42/segurProiektu/commit/c171f416217f9382bbee0ad166df80191b855af5